

I525: Economics of Information Security

L. Jean Camp

Office Hours
ZOOM!

Please see the course announcement for current and future passwords.

The issues we will explore focus on how to leverage economics to answer fundamentally human, organizational, or social questions about security and privacy behaviors of people, groups, firms, and even nations. The fundamental pedagogical approach in this class is that of a research seminar. Students are expected to come prepared to answer the basic questions that illustrate that they have completed the reading.

For each reading we answer a set of questions in class. First, what is the big cosmic question? That is, where in the world of open questions, does this paper fit?

Second, what is the smaller question? Obviously no paper, monograph, or even 42 papers can answer the big questions about life, the universe, privacy, and everything. As a result, questions are broken down into smaller elements.

Third, what is the method of the paper? The method may be a result of iteration, natural experiment, incident, or a result of the ideal scientific method. The research products we examine include empirical quantitative, exploratory qualitative, mathematical modeling, simulation, and often combinations of different methods.

Fourth, how does this method (or methodology) match and fail to match both the larger question and the immediate question at hand? Clearly these last two apply less to position papers and course sessions where the topic is tutorial.

Fifth, what are the findings of the papers? Often interdisciplinary papers use a method that fits with the data, but not the conclusion. The work may answer the small question, but assert that the results answer the larger question.

Finally, with those five questions answered, we respectfully argue about the implications of those findings. Concurrence with class opinion is not a requirement; critiques of the framing of the analyses are particularly valuable. There are significant open questions in economics of security where asserting an opinion as consensus is not reasonable.

Knowledge

- Measuring the costs of cybercrime
- The interaction of cryptocurrency and e-crime
- The infrastructure of e-crime
- The basics of risk perception, usability, and rational evaluation of risk in e-crime and privacy
- Understand security and privacy as rational, competitive economic phenomena
- Mastery of basic economic concepts
- Security and privacy as rational, competitive economic phenomena

- Security and privacy behavioral, human economic phenomena

Skills

- Examine any proposed protocol or technology to understand its basic costs/benefit proposal, including which parties bear the cost, who takes risks and receives benefits
- Identify the correct strategy given extant defenses for your organization
- Create new defenses and responses based on that understanding
- Understand the components of bitcoin as an exemplar cryptocurrency, in order to evaluate it and others
- Evaluate the relationship between assumptions and modeling in security engineering analysis
- Techniques to critique research in security and privacy, with a particular emphasis of scope of conclusions
- Approaches to critique a business claim or sales pitch with a particular emphasis on underlying assumptions, human decision-making, and organization behavior

Larger Goals within the Security Curriculum

- A well-defined bridge between concentrations in the economics and social sciences with security informatics
- An exposure to interdisciplinary approaches to security
- A contextual understanding of basic attacks and defenses
- The ability to effectively summarize and communicate interdisciplinary research

Graded Course Components

Quizzes

Quizzes are individual evaluations of mastery of the material in class. They will be on Canvas. These will be on the lecture, and only those components of the optional readings specifically in the lecture and on the slides are subject to inclusion in the quizzes. These timed multiple choice quizzes will occur at least every other week and no more often than once a week. In addition to playing a role in student evaluation, these provide critical feedback for my lecture design. There will be no fewer than ten, and no more than twenty.

Wait? There are Optional Readings?

There are optional readings and additional material in the slides for multiple reasons. The additional readings place the material in the larger research domain. Any given reading will be built upon a foundation of related work, and I use the lecture to provide a deeper exploration of this work. And any given reading also influences far more future work than you can be expected to read. Lectures will not only review the readings, but even more so provide context for these. If you are considering a course topic for a research paper (always the easiest option) these readings provide foundational materials, to distinguish between the research area or a specific method as what was engaging about the topic. Also particularly useful for those considering a research group, there are optional readings that provide an example of my own research in the area. I generally recommend that you consider completing your research with an independent study, students as often work with me as they do other faculty at Indiana in the area of cybersecurity.

Applied Activities

Periodic assignments will be posted on Canvas in order to reinforce understanding of course material and stimulate new thoughts on the topics. Normally these activities would be in small groups, face to face, in the classroom. I have moved them online. These are group activities and topical debates about a specific decision you may or may not make. Everyone in the group receives the same grade, regardless of if there is one collective assignment or if each person must deliver a result. Please note that each has a specific, pedagogical goal and in some cases I return to the assignment in later section in the lecture. These are concentrated in the first weeks of the semester with the assumption that both doctoral students in this class and students taking

other classes will have increasingly intensive project-based deadlines as the semester comes to a close. The incentive structures of these small group assignments are also designed to reflect the variety of incentive structures in different components of security and privacy.

Discussions

I will assume that discussions will occur in class, but this may not be feasible. We may move to online discussions. Do the assigned reading, and be prepared to discuss the material in either case. Online discussions, if needed, will include directions for the discussion thread. Students will only be able to see the contributions of others after their initial post. Initial posts will be due no later than Thursday at midnight of the respective week. Two other substantive posts in response to your peers are required no later than Sunday night at midnight. Two responses are the minimum to be satisfactory. Just as in the classroom active, respectful, and continued discussion in the forum is encouraged.

Research Paper (mandatory for doctoral students, optional for others)

Doctoral students enrolled in this course at the 600 level will author a research paper of suitable quality, ideally to be presented at a conference or submitted for publication. The topic of the paper will fall somewhere within the domain of “Economics of Security”. Portions of the paper will be due throughout the semester. If you are a masters student and are interested in research, please submit an abstract. Submitting an abstract can not hurt your grade.

My practice is to select a set of possible publication or submission venues and provide links to those when they are available. Your target determines your formatting. For example, I would normally expect appropriate matches to be the Workshop on Economics of Information Security, Telecommunications Policy Research Conference, or (for measurement-based papers) IEEE International Conference on Network Protocols or (for research with organizational theory components) the Hawaii International Conference on System Sciences. However, like everything else, conference deadlines underwent a period of chaos in 2020 that continues in 2021 so I will add events as I see them.

Grading Summary

Grading without a research product	
15% participation	Consistent in-class participation, or on-line as instruction changes.
10% applied assignments	These are tightly focused debates.
5% presentation evaluation	Evaluation of doctoral presentations.
70% quizzes	Timed online quizzes.

Grading with a research product	
10% participation	Doctoral students are held to a higher standard.
10% applied assignments	These are tightly focused debates.
30% quizzes	Timed online quizzes.
50% research product	Components graded as below.
5% abstract	Define a clear question, with an applicable method & access to data.
10% bibliography	At least fifteen, better 25 items, all annotated.
5% rough draft	An opportunity for feedback for the final product.
15% final paper	Answer the question, align the conclusions with the research.
10% presentation	Clearly address the question, method, data, conclusions, implications

Paper Timeline and Grading:

Abstract– 5% (due by end of week 3) In the class we ask five questions. What is the big idea? What is the researchable question? What is the method? Why? What specific hypothesis will enable what conclusions? In

this short assignment you will attempt to begin forming your own work. This is an initial idea that will be framed by the related work read in the coming weeks.

Bibliography – 10% (due by the end of week 6) The bibliography should be roughly complete by this time in the semester. This bibliography will serve as the foundation for your research paper. The annotated bibliography will justify the question and inform the method.

Rough Draft – 5% (due by the end of week 10) This is your chance for feedback before the final grade. If you are disappointed by previous grades, this is particularly important.

Final Paper – 15% (due by end of week 13) The research paper is the culmination of the semester's work.

Presentation – 10% (due by end of week 14). The presentation will consist of a video, webcast, or in-class presentation based on the public health situation at that time. I expect an overview of the research similar to presentation at a workshop. All students are required to evaluate another students' presentation, using the format provided.

Appropriate Research Paper Topics

Experiments with interaction design or risk communication on vishing, spear phishing, whaling, smishing (call the IT hotline!); USBs (don't touch that port!), or any attack or fraud. Examinations of crime markets including but not limited to fake apps, malicious scripts, particularly as these impact ransomware, denial of service, and the crime ecosystem. Reproductions of studies read in class are encouraged, but when planning on of these assume that it will be less straight-forward than it initially appears

Biden's Executive Order on Improving the Nation's Cybersecurity (<https://www.whitehouse.gov/briefing-room/presidential-actions/2021/05/12/executive-order-on-improving-the-nations-cybersecurity>) offers a wealth of research questions.

Students are highly encouraged to submit the paper for publication. A paper accepted for a conference and/or publication will result in an automatic grade of A for the course provided that the conference/publication is sufficiently rigorous and peer-reviewed. This requires that I approve the venue before submission. Note that there is some funding for graduate students to present research results; so planning to present at a domestic event is reasonable. I expect no in person events before March.

Course Policies

These policies are in addition to and not a substitute for University Academic Conduct policies.

Video and audio recording of the in person components of the course is not allowed. The class time is focused on discussion. I expect the class participants, as graduate students, to be able to answer the questions and engage fully in classroom exercises. This means that there will be moments of disagreement, and even intellectual struggle or conflict. Experience indicates and research does not contradict the assertion that recording will not only not help, but would hinder discussion and education. A violation of this class policy will be treated as a violation of academic integrity.

The discussion in the online course is a contribution and many of these are excellent. Your answers will not be reused nor shared without your explicit permission. It is possible that some students may be asked to put their materials in blog form for wider distribution, or you can volunteer to write such a post. The discussions in the class are under Chatham House Rules. After grades have been recorded, the instructors will request that the discussion material be removed. You are welcome to keep copies of materials for your own personal use. Sharing any content that other students post without explicit permissions during or after the course is a violation of student ethics. Obtain permission from any student if you want to share their insights beyond the course. The professor creating the material has the copyright for the course content material. Please do not share or use beyond the course, excluding for your personal review and records.

Primary Instructor contact will be via email. Please ensure that you put “I525” in the subject line and carbon copy the AI.

Risk and Safety in Fall 2021

One thing addressed very early cover in class is how security is a mixed good: produced by companies, by the government, and by people. Health is the same. COVID has many of the same characteristics of other risks: the exposure is not visible, the annoyance of mask-wearing is immediately salient, our vulnerability is a function of the behavior of others, and there are interactions between vulnerabilities we do not fully understand.

Instructors are allowed to teach without masks on the condition that we are at least six feet from students. I have ordered a mask with a Bluetooth mic and a small speaker. We will have to collaborate on what works in the course. I have expanded the online component of discussion and interaction by creating applied activities that otherwise would occur in closely interacting small groups in class.

In our shared responsibility for risk mitigation, if a student is present in a class without a mask, that person should be asked to put on a mask! Students are subject to reporting to the Division of Student Affairs: Office of Student Conduct. This will certainly apply the first weeks, after this the university will continually re-assess the situation. Hopefully we are all vaccinated and it will improve.

If a teaching assistant is in class, or in a physical meeting, and refuses to put on a mask that assistant should be reported to the Graduate Student Office in Luddy. My office hours will be on Zoom. If a teacher, assistant, or member of your student group wants to meet over Zoom or otherwise remotely it is class policy that every person will honor such a request by others.

Our agreement to the public health measures adopted by Indiana University is a condition of physical presence on the campus this fall. Included in this are requirements for wearing masks in all IU buildings and maintaining social distancing in all IU buildings. Both are classroom requirements.

Both requirements are necessary for us to protect each other. If you ask that I wear a mask as you feel uncomfortable and you feel unsafe or disrespected it is your right to contact the Chair, or the Dean of Faculty Affairs. Violation of the mask rule is a threat to public safety.

The official policy is as follows.

- If a student refuses to put a mask on after being asked to do so, the instructor may end the class immediately, and contact the Office of Student Conduct. Violation of the mask rule is a threat to public safety within the meaning of the Summary Suspension Policy .
- If a student comes to class without a mask twice, the student’s final grade will be reduced by one letter (e.g., from an A to a B, for instance).
- If the student comes to class without a mask three times, the student will be withdrawn from the class without refund of tuition and reported to the Office of Student Conduct.
- If Student Conduct receives three cumulative reports from any combination of instructors or staff members that a student is not complying with the requirements of masking and physical distancing, the student will be summarily suspended from the university for the semester.

Our great shared hope is that some weeks into the semester the risk becomes such that these policies are no longer necessary. Our common concern is that the entire semester will be made virtual. Any policy change will be immediately reflected in the organization of the course.

Schedule of Topics & Readings

Why don't people and organizations engage in on-line self-protection? We can find answers if we view the problem through the lens of economics.

The course is completely redesigned from previous years, based on a conception of three explanations of why the state of security and privacy is so worthy of concern: rational decision-making, the limits of decision-making under uncertainty, and systems designs that presume literally superhuman abilities.

1. Course Structure and Motivation

Tuesday Aug 24

This is the only session where you **will not be expected** to have completed the reading.

Syllabus -sessions, policies, and purposes

The theory underlying the course structure is empirically supported by Vaibhav Garg, Kevin Benton, and L. Jean Camp. The privacy paradox: a FaceBook case study. In Telecommunications Policy Research Conference, 2014.

Illustrative example: Solar Winds

Thursday Aug 26

Anderson, Ross, and Tyler Moore. "The economics of information security." Science 314.5799 (2006): 610-613. <http://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.477.2090>

Ross Anderson, Chris Barton, Rainer Boehme, Richard Clayton, Michel J.G. van Eeten, Michael Levi, Tyler Moore, Stefan Savage, Measuring the Cost of Cybercrime weis2012.econinfosec.org/papers/Anderson_WEIS2012.pdf

Current numbers from the FBI Internet Crime Complaint Center report from 2020 https://www.ic3.gov/Media/PDF/AnnualReport/2020_IC3Report.pdf

Applied

Evaluate adding the Russian keyboard configuration. Describe on Canvas.

<https://krebsonsecurity.com/2021/05/try-this-one-weird-trick-russian-hackers-hate/>

2. eCrime Infrastructure

Tuesday Aug 31

Janos Szurdi & Nicolas Christin, "Domain registration policy strategies and the fight against online crime", WEIS 2018

https://weis2018.econinfosec.org/wp-content/uploads/sites/5/2016/09/WEIS_2018_paper_45.pdf

Christian Kreibich, Chris Kanich, Kirill Levchenko, Brandon Enright, Geoffrey M. Voelker, Vern Paxson, and Stefan Savage, Spamcraft: An Inside Look at Spam Campaign Orchestration. Proceedings of the USENIX Workshop on Large-scale Exploits and Emergent Threats (LEET), Boston, MA, April 2009, pages 4:1 - 4:9. https://www.usenix.org/legacy/event/leet09/tech/full_papers/kreibich/kreibich.pdf

Clayton, Richard. "How much did shutting down McColo help." Proc. of 6th CEAS (2009).

Thursday Sept 2

Vulnerability Disclosure Framework, the Original- <https://www.dhs.gov/xlibrary/assets/vdwgreport.pdf>

Andrew Dingman, Gianpaolo Russo, "Risk-Based Vulnerability Disclosure: Towards Optimal Policy" https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2601191

Bohme, R. Vulnerability markets: What is the economic value of a zero-day exploit? In Proc. of 22C3 (2015), pp. 27–30.

Applied:

Select the most recent vulnerability reported in the NVD

Describe in the online discussion how you would know if you should take action for your own machine.

Rational Choice Models

Why do businesses systematically neglect security? Why is it that vulnerabilities known in 2015 can be damaging in 2021? For these sessions we use standard economic models to explain why one individual company might choose not to invest in security, the variables that can make what seems a wildly risk-seeking decision into a reasonable choice. Of course, understanding does not require agreement or disagreement.

3. Rational Market Assumptions

Tuesday Sept 7

A. Michael Froomkin, J. Bradford De Long, “Speculative Microeconomics for Tomorrow's Economy”, <http://personal.law.miami.edu/~froomkin/articles/spec.htm>

Thursday Sept 9

Hal Varian, System Reliability and Free Riding, eds. N. Sadden, Proceedings of the ICEC 2003, 2003, 355-366, ACM Press, New York, NY, <http://people.ischool.berkeley.edu/~hal/Papers/2004/reliability>

Short work: Hal R. Varian, How to Build an Economic Model in Your Spare Time
www.sims.berkeley.edu/~hal/Papers/how.pdf

Applied:

Describe how different grading rubrics in your courses have created similar effects in group projects; Average effort, the best achiever, and the least contributor defining the grade.

4. The Rational Business

Tuesday Sept. 14

Gordon, L.A. and Loeb, M.P. (2002) The Economics of Information Security Investment. ACM Transactions on Information and System Security, 5, 438-457. <http://dx.doi.org/10.1145/581271.581274>

Moore, T., Dynes, S., & Chang, F. R. (2015). Identifying how firms manage cybersecurity investment download. Southern Methodist University. <http://blog.smu.edu/research/files/2015/10/SMU-IBM.pdf>

Wilemson, “On the Gordon & Loeb Model for Information Security Investment”
<http://www.econinfosec.org/archive/weis2006/docs/12.pdf>

Optional:

Cartwright, E., Castro, J.H., & Cartwright, A. (2018). To pay or not: Game theoretic models of ransomware. Journal of Cybersecurity, 5(1), tyz009.

Moore, Dynes, Change, “Identifying How Firms Manage Cybersecurity Investment” <http://www-01.ibm.com/common/ssi/cgi-bin/ssialias?htmlfid=WGL03090USEN>

Thursday Sept 16

August, Dao, Kim, “Market Segmentation and Software Security: Pricing Patching Rights”
http://weis2016.econinfosec.org/wp-content/uploads/sites/2/2016/05/WEIS_2016_paper_33-2.pdf

Ashish Arora and Christopher M. Forman and Anand Nandkumar and Rahul Telang, Competitive and Strategic Effects in the Timing of Patch Release, Fifth Workshop on the Economics of Information Security, 2006, Cambridge, UK, available online, at <http://weis2006.econinfosec.org/docs/35.pdf>

5. *The Rational Business*

Tuesday Sept 21

Rahul Telang, and Sunil Wattal, Impact of Software Vulnerability Announcements on the Market Value of Software Vendors -- an Empirical Investigation, Fourth Workshop on the Economics of Information Security, 2005, Cambridge, MA, available online, at http://infosec.net/workshop/pdf/telang_wattal.pdf

Sam Ransbotham, Sabyasachi Mitra, The Impact of Immediate Disclosure on Attack Diffusion and Volume, WEIS 2011, <http://weis2011.econinfosec.org/papers/TheImpactofImmediateDisclosureonAttackDiffusionand.pdf>

Thursday Sept 23

Ioannidis, C., Pym, D., & Williams, J. (2012). Information security trade-offs and optimal patching policies. *European Journal of Operational Research*, 216(2), 434-444.

Cavusoglu, H., Cavusoglu, H., & Zhang, J. (2008). Security patch management: Share the burden or share the damage? *download. Management Science*, 54(4), 657-670.

Applied

Google released vulnerabilities on a 90 day schedule. Microsoft patches on a difference schedule. Break into the two sides and debate the issue in discussion.

<https://www.pcworld.com/article/2867533/google-reveals-windows-81-flaw-mere-days-before-patch-tuesday-fix-irking-microsoft.html>

<https://www.neowin.net/news/google-project-zero-reveals-another-windows-elevation-of-privilege-vulnerability/>

<https://www.engadget.com/2015-01-02-google-posts-unpatched-microsoft-bug.html>

6. *The Rational Attacker*

Tuesday Sept 28

Zhenhai Duan, Kartik Gopalan, Xin Yuan An empirical study of behavioral characteristics of spammers: Findings and implications *Computer Communications* Vol. 34, Iss. 14, September 1 2011, 1764-1776, <http://www.cs.fsu.edu/~duan/publications/icc2007.pdf>

Garg, Vaibhav, Thomas Koster, and L Jean Camp. "Cross-country analysis of spambots." *EURASIP Journal on Information Security* 2013.1 (2013): 1. <http://jis.eurasipjournals.springeropen.com/articles/10.1186/1687-417X-2013-3>

Clayton, Richard. "Do zebras get more spam than aardvarks?." *ratio* 20 (2008): 40. <https://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.161.3653>

Thursday Sept 30

Moriano, P., Achar, S., & Camp, L. J. (2017). Incompetents, criminals, or spies: Macroeconomic analysis of routing anomalies. *Computers & Security*, 70, 319-334.

V. Garg, L Jean Camp, *Macroeconomic Analysis of Malware*, NDSS, 2013.

Michel van Eeten, Johannes M. Bauer, Hadi Asghari, Shirin Tabatabaie and Dave Rand, The Role of Internet Service Providers in Botnet Mitigation: An Empirical Analysis Based on Spam Data The Ninth Workshop on the Economics of Information Security (WEIS 2010), Harvard University, 7-8 June 2010, http://weis2010.econinfosec.org/papers/session4/weis2010_vaneeten.pdf

Optional

Garg, Vaibhav, L. Jean Camp, and Chris Kanich. "Analysis of ecrime in crowd-sourced labor markets: Mechanical turk vs. freelancer." *The economics of information security and privacy*. Springer Berlin Heidelberg, 2013. 301-321.

Applied

Is it rational for Russia to support crime and spam? Please pick teams and have a discussion of at least two statements each. Associated reading: Spam nation Chapter 1

7. Addressing the Lemons Market

Tuesday: Oct 5

Vaibhav Garg. A lemon by any other label. In ICISSP, pages 558–565, 2021.

<https://www.scitepress.org/Papers/2021/102952/102952.pdf>

Sasse, M. A., Kirlappos, I. (2012). Familiarity breeds con-victims: Why we need more effective trust signaling. Springer-Verlag. http://link.springer.com/chapter/10.1007%2F978-3-642-22200-9_2

Optional

George A Akerlof. The market for “lemons”: Quality uncertainty and the market mechanism. In Peter Diamond and Michael Rothschild, editors, *Uncertainty in Economics*, pages 235 – 251. Academic Press, 1978.

L Jean Camp, Reliable, Usable Signaling to Defeat Masquerade Attacks, Fifth Workshop on the Economics of Information Security, 2006, Cambridge, UK <http://weis2006.econinfosec.org/docs/48.pdf>

Thursday: Oct 7

Kristián Kozák, Bum Jun Kwon, Doowon Kim & Tudor Dumitraş, Issued for abuse: measuring the underground trade in code signing certificates https://weis2018.econinfosec.org/wp-content/uploads/sites/5/2018/06/WEIS_2018_paper_14.pdf

Nevena Vratonjic, Julien Freudiger, Vincent Bindschaedler, and Jean-Pierre Hubaux (all EPFL, Switzerland), The Inconvenient Truth about Web Certificates, The Tenth Workshop on the Economics of Information Security (WEIS 2011), GMU, 14-15 June 2011, <http://infoscience.epfl.ch/record/165676/files/WEIS11-Vratonjic.pdf>

Benjamin Edelman, Adverse Selection in Online 'Trust' Certifications, Fifth Workshop on the Economics of Information Security, 2006, Cambridge, UK, <http://weis2006.econinfosec.org/docs/10.pdf>

Applied

Select two IoT devices in a class; for example, fitness trackers, lightbulbs, thermostats. Locate the associated privacy policy. Each group member should quickly summarize the data types and to who they are shared. Note your sources. Then share your results and determine if you agree with each other, note any discrepancies and if this is a result of the search method.

8. Privacy Behavior as Rational

Tuesday: Oct 12

Aleecia M McDonald and Lorrie Faith Cranor. The cost of reading privacy policies. ISJLP, 4:543, 2008.

Vila, T., Greenstadt, R., & Molnar, D. (2003, September). Why we can't be bothered to read privacy policies models of privacy economics as a lemons market. In *Proceedings of the 5th international conference on Electronic commerce* (pp. 403-407).

Jensen, Carlos, and Colin Potts. "Privacy policies as decision-making tools: an evaluation of online privacy notices." In *Proceedings of the SIGCHI conference on Human Factors in Computing Systems*, pp. 471-478. 2004.

Thursday: Oct 14

Privacy as a Complementary or Bundled Good. In class we discuss substitutes, complements, bundling.

Ramnath K. Chellappa, Shivendu Shivendu, Incentive Design for Free but No Free Disposal Services: The Case of Personalization under Privacy Concerns, WEIS 2007 - Sixth Workshop on Economics of Information Security, Pittsburgh PA, 7-8 June 2007 <http://weis07.infosecon.net/papers/48.pdf>

9. Individual Decisions and Common Pools

Tuesday: Oct 19

Odlyzko, Privacy and Price Discrimination CH 15, pp 187-21
www.dtc.umn.edu/~odlyzko/doc/privacy.economics.pdf

Rainer Bohme and Sven Koble, On the Viability of Privacy-Enhancing Technologies in a Self-Regulated Business-to-Consumer Market: Will Privacy Remain a Luxury Good?, WEIS 2007 - Sixth Workshop on Economics of Information Security, Pittsburgh PA, 7-8 June 2007.
<http://weis07.infosecon.net/papers/30.pdf>

Roger Dingledine and Nick Mathewson, Anonymity Loves Company,
<https://www.cs.tufts.edu/~nr/cs257/archive/roger-dingledine/anonymity.pdf>

Thursday: Oct 21

Dong, Zheng, Vaibhav Garg, L. Jean Camp, and Apu Kapadia. "Pools, clubs and security: designing for a party not a person." In Proceedings of the 2012 New Security Paradigms Workshop, pp. 77-86. ACM, 2012.

Sauerwein, C., Gander, M., Felderer, M., & Breu, R. (2016, March). A systematic literature review of crowdsourcing-based research in information security. In Service-Oriented System Engineering (SOSE), 2016 IEEE Symposium on (pp. 364-371). IEEE.

Applied

Cormac Herley, Why do Nigerian Scammers Say They are from Nigeria?",
<http://research.microsoft.com/pubs/167719/whyfromnigeria.pdf>
Look for a scam email within your group's collective in-boxes. Look for indicators and explain why these do or do not exist in this particular fraud attempt.

Decision-Making and Uncertainty

In this section we will focus on heuristics, biases, and risk perception. The limits of the applicability of the model of homo economicus will be used to discuss both decision-making by firms in network security and individuals with respect to privacy. Concepts of risk aversion and risk perception will be introduced. By beginning with the framework of behavioral economics, it may be easier to understand the framework that underlies rational economics.

10. Psychology of Security

Tuesday: Oct 26

West, Ryan. "The psychology of security." Communications of the ACM 51.4 (2008): 34-40.
<http://delta.cs.cinvestav.mx/~francisco/ssi/p34-west.pdf>

V. Garg, and L. Jean Camp, Heuristics and Biases: Implications for Security Design, IEEE Technology & Society, Mar. 2013. <http://www.ljean.com/files/Biases.pdf>

Optional:

Zeckhauser, Richard, "Behavioral versus Rational Economics," in Rational Choice: The Contrast between Economics and Psychology, Robin M. Hogarth and Melvin W. Reder, eds., Chicago: University of Chicago Press, 1986, pp. 251-265

D. Kahneman, Paul Slovic & Amos Tversky (1982) Judgment Under Uncertainty: Heuristics and Biases (Cambridge University Press). (excerpt)

Thursday: Oct 28

Dhamija, R., Tygar, J. D., & Hearst, M. (2006, April). Why phishing works. In Proceedings of the SIGCHI conference on Human Factors in computing systems (pp. 581-590).

Camp, L. J., Grobler, M., Jang-Jaccard, J., Probst, C., Renaud, K., & Watters, P. (2019, January). Measuring human resilience in the face of the global epidemiology of cyber attacks. In Proceedings of the 52nd Hawaii International Conference on System Sciences.

Optional:

Gopavaram, S., Dev, J., Grobler, M., Kim, D., Das, S., & Camp, L. J. (2021, May). Cross-National Study on Phishing Resilience. In Proceedings of the Workshop on Usable Security and Privacy (USEC). https://www.researchgate.net/profile/Shakthidhar-Gopavaram/publication/350978906_Cross-National_Study_on_Phishing_Resilience/links/60a31d24299bf1d21d6d0f32/Cross-National-Study-on-Phishing-Resilience.pdf

11. Warnings as Risk Communication

Tuesday: Nov 2

David Modic, Ross J. Anderson Reading this May Harm Your Computer: The Psychology of Malware Warnings, http://papers.ssrn.com/sol3/papers.cfm?abstract_id=2374379

Chia, Pern Hui, Yusuke Yamamoto, and N. Asokan. "Is this app safe?: a large scale study on application permissions and risk signals." Proceedings of the 21st international conference on World Wide Web. ACM, 2012. <http://www.academia.edu/download/30629969/www2012.pdf>

Van Schaik, Paul, et al. "Security and privacy in online social networking: Risk perceptions and precautionary behaviour." Computers in Human Behavior 78 (2018): 283-297.

Optional

Roman Schlegel, Apu Kapadia, and Adam J. Lee. Eyeing Your Exposure: Quantifying and Controlling Information Sharing for Improved Privacy. In Proceedings of the Seventh Symposium on Usable Privacy and Security, SOUPS '11, pages 14:1–14:14, New York, NY, USA, 2011. ACM.

A presentation on risk perception from Microsoft research: <http://research.microsoft.com/apps/video/default.aspx?id=158037>

Thursday: Nov 4

Asgharpour, Farzaneh, Debin Liu, and L. Jean Camp. "Mental models of security risks." International conference on financial cryptography and data security. Springer, Berlin, Heidelberg, 2007.

Wash, R. and Rader, E., 2011, September. Influencing mental models of security: a research agenda. In Proceedings of the 2011 New Security Paradigms Workshop (pp. 57-66).

Volkamer, M., & Renaud, K. (2013). Mental models—general introduction and review of their application to human-centred security. In Number Theory and Cryptography (pp. 255-280). Springer, Berlin, Heidelberg.

Optional:

Kang, Ruogu, Laura Dabbish, Nathaniel Fruchter, and Sara Kiesler. "“my data just goes everywhere:” user mental models of the internet and implications for privacy and security." In Eleventh Symposium On Usable Privacy and Security, pp. 39-52. 2015.

12. Privacy Behaviors

Tuesday: Nov 9

Alessandro Acquisti, Laura Brandimarte, and George Loewenstein. Privacy and human behavior in the age of information. Science, 347(6221):509–514, 2015.

Thursday: Nov 11

Shakthidhar Gopavaram, Jayati Dev, Sanchari Das, and L Jean Camp. IoT Marketplace: Willingness-To-Pay vs. Willingness-To-Accept. In Proceedings of the 20th Annual Workshop on the Economics of Information Security (WEIS 2021), 2021

Jens Grossklags and Alessandro Acquisti. When 25 Cents is Too Much: An Experiment on Willingness-To-Sell and Willingness-To-Protect Personal Information. WEIS 2007, Carnegie Mellon University, Pittsburgh, PA, USA, June 7-8, 2007

Optional

Shane D Johnson, John M Blythe, Matthew Manning, and Gabriel TW Wong. The impact of IoT security labelling on consumer product choice and willingness to pay. PloS one, 15(1):e0227800, 2020.

Eric J. Johnson, Steven Bellman, and Gerald L. Lohse. Defaults, Framing and Privacy: Why Opting In-Opting Out. Marketing Letters, 13(1):5–15, Feb 2002.

Human Factors

People may not choose to use security technologies because of their perceived cost, or inability to do so. When we discuss usability in security we are often identifying stop points: people literally can not use the technology that is being developed.

13. Behavior in Patching & Attacking

Tuesday: Nov 16

Vania, K. E., Rader, E., & Wash, R. (2014, April). Betrayed by updates: how negative experiences affect future security. In Proceedings of the SIGCHI Conference on Human Factors in Computing Systems (pp. 2671-2674).

Ion, Iulia, Rob Reeder, and Sunny Consolvo. "... no one can hack my mind": Comparing Expert and Non-Expert Security Practices." Eleventh Symposium On Usable Privacy and Security ({SOUPS} 2015). 2015. <https://www.usenix.org/system/files/conference/soups2015/soups15-paper-ion.pdf>

Fagan, M. and Khan, M.M.H., 2016. Why do they do what they do?: A study of what motivates users to (not) follow computer security advice. In Twelfth Symposium on Usable Privacy and Security ({SOUPS} 2016) (pp. 59-75). <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/fagan>

Thursday: Nov 18

Luca Allodi, Fabio Massacci & Julian Williams, The Work-Averse Cyber Attacker Model: Theory and Evidence From Two Million Attack Signatures WEIS 2017 http://weis2017.econinfosec.org/wp-content/uploads/sites/3/2017/05/WEIS_2017_paper_13.pdf

Collier, Ben, Richard Clayton, Alice Hutchings, and Daniel Thomas. "Cybercrime is (often) boring: infrastructure and alienation in a deviant subculture." The British Journal of Criminology (2021).

<https://www.repository.cam.ac.uk/bitstream/handle/1810/306682/Pubilshed%20paper.pdf?sequence=5>

Garg, V. and Camp, L.J., 2015. Why cybercrime?. ACM SIGCAS Computers and Society, 45(2), pp.20-28.

14. Privacy and Passwords as Human Factors

Tuesday: Nov 23

L Wathieu, A Friedman, "An Empirical Approach to Understanding Privacy Valuation" https://papers.ssrn.com/sol3/papers.cfm?abstract_id=982593

Good, Grossklags, Thaw, Persanowski, Mulligan, Konstan, "User Choices and Regret: Understanding Users' Decision Process About Consensually Acquired Spyware"
https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2262437

Optional

Wang, Komanduri, Norice, Leon, Acquisti, Cranor, "I regretted the minute I pressed share": A Qualitative Study of Regrets on Facebook" <https://www.andrew.cmu.edu/user/pgl/FB-Regrets.pdf>

G Danezis, S Lewis, RJ Anderson "How much is location privacy worth?"
<http://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.335.5193>

Thursday: Nov 25

Inglesant, Philip G., and M. Angela Sasse. The true cost of unusable password policies: password use in the wild., Proceedings of the SIGCHI Conference on Human Factors in Computing Systems. ACM, 2010.

Camp, L. J., Abbott, J., & Chen, S. (2016, January). Cpasswords: Leveraging episodic memory and human-centered design for better authentication. In 2016 49th Hawaii International Conference on System Sciences (HICSS) (pp. 3656-3665). IEEE.

Biddle, R., Chiasson, S. and Van Oorschot, P.C., 2012. Graphical passwords: Learning from the first twelve years download. ACM Computing Surveys (CSUR),44(4), p.19.

Das, S., Dingman, A., & Camp, L. J. (2018, February). Why Johnny doesn't use two factor a two-phase usability study of the FIDO U2F security key. In International Conference on Financial Cryptography and Data Security (pp. 160-179). Springer, Berlin, Heidelberg.

15. Ransomware

Tuesday: Nov 30

Young, A. L., & Yung, M. (2017). Cryptovirology: The birth, neglect, and explosion of ransomware. Communications of the ACM, 60(7), 24-26.

Richardson, Ronny, and Max M. North. "Ransomware: Evolution, mitigation and prevention." downloadInternational Management Review 13.1 (2017): 10.

Al-rimy, B. A. S., Maarof, M. A., & Shaid, S. Z. M. (2018). Ransomware threat success factors, taxonomy, and countermeasures: downloadA survey and research directions. Computers & Security, 74, 144-166.

Thursday: Dec 2

C. Dower and M. Na-or, Pricing via Processing or Combating Junk Mail, 1992. In E. F. Brick (Ed.): Advances in Cryptology-CRYPTO 1992, Springer-Verlag, pp. 139-147.<http://web.cs.dal.ca/~abrodsky/7301/readings/DwNa93.pdf>

Rivest, R. L., & Shamir, A. (1996, April). PayWord and MicroMint: Two simple micropayment schemes. In International workshop on security protocols (pp. 69-87). Springer, Berlin, Heidelberg.

Haber, Stuart, and W. Scott Stornetta. "How to time-stamp a digital document." Conference on the Theory and Application of Cryptography. Springer Berlin Heidelberg, 1990.
http://webtest.anf.es/ec/pdf/Haber_Stornetta.pdf

16. Bitcoin

Tuesday: Dec 7

Bentov, I., Gabizon, A., & Mizrahi, A. (2016, February). Cryptocurrencies without proof of work. Financial Cryptography (pp. 142-157). Springer, Berlin, Heidelberg.

<https://arxiv.org/pdf/1406.5694.pdf>

Ben Laurie and Richard Clayton, Proof-of-Work Proves Not to Work, Third Workshop on the Economics of Information Security, 2004, Minneapolis, MN, available online, at <http://www.dtc.umn.edu/weis2004/clayton.pdf>

Debin Liu and L. Jean Camp, Proof of Work Can Work, WEIS 2006 (Cambridge, UK) 26-28 June 2006. <http://weis2006.econinfosec.org/docs/50.pdf>

Optional

Nakamoto, Satoshi. "Bitcoin: A peer-to-peer electronic cash system." <https://bitcoin.org/bitcoin.pdf>

Thursday: Dec 9

Danny Yuxing Huang, Hitesh Dharmdasaniy, Sarah Meiklejohn, Vacha Dave, Chris Grier, Damon McCoy, Stefan Savage, Nicholas Weaver, Alex C. Snoeren and Kirill Levchenko, Botcoin: Monetizing Stolen Cycles <http://cseweb.ucsd.edu/~snoeren/papers/botcoin-ndss14.pdf>

Masarah Paquet-Clouston, Bernhard Haslhofer & Benoit Dupont, "Ransomware payments in the Bitcoin ecosystem", WEIS 2018 https://weis2018.econinfosec.org/wp-content/uploads/sites/5/2018/05/WEIS_2018_paper_21.pdf

Kevin Liao, Ziming Zhao, Adam Doupe, Gail Joon Ahn, "Behind closed doors: Measurement and analysis of CryptoLocker ransoms in Bitcoin" <https://asu.pure.elsevier.com/en/publications/behind-closed-doors-measurement-and-analysis-of-cryptolocker-rans>

Exam Period

This will likely be online

All those completing research papers will present them.

All will evaluate the presentation using our overall discussion rubric.